

Damian Świdorski

Specjalista ds. Cyberbezpieczeństwa
PROJEKT KOŃCOWY - CZĘŚĆ TEORETYCZNA

AKTUALNY PROFIL ORGANIZACJI

Nazwa: SpeedWay

Branża: Spedycja

Liczba pracowników: 100

Struktura: 20 osób (zarząd i administracja), 80 spedytorów

Lokalizacja(e): Jedno biuro (siedziba)

INFRASTRUKTURA IT:

- Stacje robocze: 100 laptopów (OS: Windows 11)

- Serwery: 5 (role: Kontroler Domeny (AD), Serwer Plików, Serwer Aplikacyjny TMS, Serwer Bazy Danych, Serwer Kopii Zapasowych)

└ Lokalizacja: on-prem 3 / cloud 2 / hybrid -

- Kluczowe systemy biznesowe: System operacyjny TMS (Transport Management System), System finansowo-księgowy ERP

- Infrastruktura sieciowa:

└ Firewall: Fortinet FortiGate 60F

└ Segmentacja: Nie (VLANy: BRAK)

└ VPN: Tak (typ: podstawowy VPN SSL dla pracy zdalnej)

└ WiFi: Tak (guest network: Nie)

- Cloud services:

└ Email/Collaboration: Microsoft 365 (Exchange Online, Teams)

└ Storage: SharePoint / OneDrive

└ IaaS/PaaS: Microsoft Azure

└ SaaS apps: Giełda transportowa (Trans.eu)

- Backup: Gdzie/Jak: Backup wykonywany codziennie w nocy na lokalny dysk NAS w serwerowni

- IT/Security team: 2 osoby (security specialist: Tak)

KONTEKST BIZNESOWY:

- Krytyczne procesy: Kluczowe dla działania przedsiębiorstwa jest płynna obsługa zleceń na giełdzie transportowej oraz u armatorów, śledzenie ładunków, ciągła komunikacja e-mail z przewoźnikami i klientami, fakturowanie.
- Typy danych: Firma przetwarza dane klientów, dane osobowe przewoźników, dane finansowe (faktury), dokumenty transportowe (CMR, faktury handlowe, packing listy).
- Compliance: Przedsiębiorstwo podlega pod RODO oraz wymogi bezpieczeństwa, które są wymagane przez kontrahentów.
- Risk appetite: Niski

Firma zarabia tylko wtedy, gdy spedytorzy mają dostęp do systemu TMS, giełdy i e-maili. Każdy przestój (nawet chwilowy) oznacza utratę zleceń, kary umowne i możliwość utraty reputacji u kontrahentów.

OBECNA SYTUACJA SECURITY:

Istniejące zabezpieczenia:

- Firewall: Tak (jaki: Fortinet)
- Antywirus/EDR: Podstawowy Windows Defender
- Backupy: Jak często: Codziennie w nocy, Gdzie: Lokalny serwer NAS
- Polityki security: Nie (jakie: hasła są zmieniane sporadycznie, brak wymogu MFA)
- Szkolenia pracowników: Ostatnie: Tylko BHP, zero szkoleń z cyberbezpieczeństwa

Incydenty i problemy:

1. Zagubienie lub kradzież laptopa służbowego, na którym dysk nie był zaszyfrowany (brak BitLockera), co powoduje ryzyko wycieku bazy klientów.
2. Phishing wycelowany w spedytorów związany z fałszywymi fakturami od przewoźników.
3. Pracownicy mają te same hasła do systemów wewnętrznych jak i do systemów zewnętrznych (np. giełdy transportowe, systemy armatorów).
4. Brak ewidencji wydanych urządzeń dla użytkowników oraz możliwość użytkowania prywatnych pendrive'ów.

Dlaczego organizacja TERAZ potrzebuje projektu security:

Zarząd zdał sobie sprawę z zagrożenia po kilku próbach wyłudzenia pieniędzy (fałszywe faktury) oraz możliwych złośliwych oprogramowań, które mogą być w nich zawarte. Duży kontrahenci zaczynają wymagać udokumentowanej polityki bezpieczeństwa. Firma nie posiada weryfikacji dwuetapowej (MFA), czy bezpiecznego backup'u w systemie 3-2-1, co przy modelu pracy opartym na szybkich decyzjach i komunikacji e-mailowej wystawia ją na krytyczne ryzyko utraty płynności finansowej.

Część I – Discovery i Planowanie

1. Streszczenie wykonawcze

- Opis organizacji i jej kontekstu biznesowego

SpeedWay jest firmą spedycyjną zatrudniającą 100 osób. Kontekst biznesowy opiera się na ciągłej dostępności systemu TMS, giełdy transportowej, systemów armatorskich i niezawodnej komunikacji e-mail.

- Obecna sytuacja bezpieczeństwa i najważniejsze problemy

Poziom bezpieczeństwa jest niski i opiera się na mało bezpiecznych praktykach (płaska sieć, brak MFA, lokalny backup). Główne problemy to skuteczne ataki phishingowe, brak szyfrowania danych na laptopach oraz takie same hasła w systemach służbowych i zewnętrznych.

- Główne cele projektu

Głównym celem jest zabezpieczyć firmę przed szyfrującymi ransomware (zablokowanie dostępu do systemów oraz danych) oraz oszustwami finansowymi (phishing - fałszywe faktury), a także dostosować procedury do wymogów RODO i standardów kontrahentów.

- Wybrany framework i uzasadnienie wyboru

CIS Controls v8 (Implementation Group 1)- zestaw 56 najbardziej krytycznych, rekomendowanych zabezpieczeń, idealny dla średnich firm z dwuosobowym działem IT, pozwalający na szybkie obniżenie ryzyka przy racjonalnych kosztach.

2. Analiza luk w zabezpieczeniach

- Ocena obecnego stanu zabezpieczeń

Znaczne braki w podstawowych mechanizmach ochrony tożsamości (MFA) i ochrony urządzeń końcowych.

- Identyfikacja luk i słabości (mapowanie na wybrany framework)

Identyfikacja luk została oparta na 56 podstawowych zabezpieczeniach (Safeguards) z Grupy Implementacyjnej 1 (IG1). Główne słabości zmapowano na następujące kontrole:

CIS Control 5 & 6 (Account Management & Access Control Management): Krytyczna luka polegająca na braku logowania dwuskładnikowego (MFA) do kluczowych usług (VPN, Microsoft 365) oraz brak kontroli nad hasłami.

CIS Control 3 (Data Protection): Wysoka luka związana z brakiem szyfrowania dysków na laptopach (BitLocker), co bezpośrednio wystawia firmę na naruszenia RODO w przypadku kradzieży sprzętu.

CIS Control 11 (Data Recovery): Wysoka luka polegająca na trzymaniu jedynej kopii zapasowej w tej samej lokalizacji fizycznej, co łamie zasady bezpiecznego backupu.

CIS Control 12 (Network Infrastructure Management): Średnia/Wysoka luka wynikająca z braku segmentacji sieci (VLAN), co pozwala potencjalnemu atakującemu na swobodne przemieszczanie się po całej infrastrukturze firmy.

CIS Control 14 (Security Awareness and Skills Training): Krytyczna luka organizacyjna – pracownicy nie potrafią identyfikować zagrożeń e-mailowych, co potwierdzają incydenty z fałszywymi fakturami.

- o Macierz: obszar security → obecny stan → brakujące elementy

Obszar Security (CIS Control)	Obecny stan	Brakujące elementy
CIS Control 5 & 6 (Account Management & Access Control Management)	Logowanie do VPN oraz poczty M365 odbywa się wyłącznie za pomocą loginu i hasła.	Wymuszenie logowania dwuetapowego (MFA) dla wszystkich dostępów zdalnych.
CIS Control 3 (Data Protection)	Dyski w 100 laptopach służbowych nie są szyfrowane (ogromne ryzyko wycieku bazy klientów przy kradzieży).	Uruchomienie i wymuszenie szyfrowania BitLocker na wszystkich laptopach z centralnym zapisem kluczy odzyskiwania.
CIS Control 11 (Data Recovery)	Backupy wykonywane są codziennie, ale zapisywane tylko lokalnie na dysku NAS w tej samej serwerowni.	Kopia zapasowa offline (w chmurze) zgodna z regułą 3-2-1, posiadająca mechanizm niezmienności danych chroniący przed ransomware.
CIS Control 12 (Network Infrastructure Management)	Płaska sieć (wszyscy widzą wszystko). Goście i prywatne telefony pracowników korzystają z tej samej podsieci co serwery firmowe.	Skonfigurowanie segmentacji (VLAN) na posiadanym firewallu Fortinet (odseparowanie laptopów, serwerów i stworzenie izolowanej sieci Guest WiFi).
CIS Control 14 (Security Awareness and Skills Training)	Całkowity brak szkoleń z zakresu cyberbezpieczeństwa. Pracownicy są podatni na ataki phishingowe.	Wdrożenie regularnych szkoleń oraz prowadzenie symulowanych kampanii phishingowych.

3. Ocena ryzyka

- o Top 5-10 ryzyk cybernetycznych dla organizacji
1. Przejęcie konta e-mail spedytora poprzez zainfekowane pliki z fakturami i wyłudzenia przelewów fałszywymi fakturami.
 2. Zaszifrowanie kluczowych serwerów i laptopów przez złośliwe oprogramowanie, zatrzymujące pracę.
 3. Dostęp do firmy nieproszonych osób przez VPN, które przejęły dane logowania pracowników z zewnętrznych stron.
 4. Zagubienie, bądź kradzież laptopa, co oznacza dostęp do nie zaszyfrowanego dysku.
 5. Awaria jedynego dysku NAS z kopiami zapasowymi.

- Ocena prawdopodobieństwa i wpływu (z uzasadnieniem biznesowym)

Ryzyko 1: Przejęcie konta e-mail spedytora poprzez zainfekowane pliki z fakturami i wyłudzenia przelewów fałszywymi fakturami.

Prawdopodobieństwo: WYSOKIE, firma doświadcza przyływ fałszywych e-maili

Wpływ: KRYTYCZNY, utrata środków finansowych

Ryzyko 2: Zaszifrowanie kluczowych serwerów i laptopów przez złośliwe oprogramowanie, zatrzymujące pracę.

Prawdopodobieństwo: ŚREDNIE/WYSOKIE, płaska sieć (bez VLANów)

Wpływ: KRYTYCZNY, brak dostępu do systemów, utrata wiarygodności u kontrahentów poprzez brak kontroli nad ładunkami

Ryzyko 3: Dostęp do firmy nieproszonych osób przez VPN, które przejęły dane logowania pracowników z zewnętrznych stron.

Prawdopodobieństwo: WYSOKIE, pracownicy mają te same hasła do dostępów firmowych jak i do aplikacji/stron zewnętrznych

Wpływ: WYSOKI, cyberprzestępcy, którzy uzyskają dostęp do zewnętrznych portali pracownika, mają również dostęp do firmy wewnątrz

Ryzyko 4: Zagubienie, bądź kradzież laptopa, co oznacza dostęp do nie zaszyfrowanego dysku.

Prawdopodobieństwo: WYSOKIE, poprzez nieuważność pracownika i zgubienie/kradzież laptopa może spowodować wyciek danych

Wpływ: ŚREDNI/WYSOKI, kara z Urzędu Ochrony Danych Osobowych za naruszenie RODO, utrata bazy klientów

Ryzyko 5: Awaria jedynego dysku NAS z kopiami zapasowymi.

Prawdopodobieństwo: NISKIE/ŚREDNIE, możliwy pożar, bądź ransomware szyfrujący

Wpływ: KRYTYCZNY, brak możliwości odtworzenia backupu, co oznacza utratę danych firmowych

- Priorytetyzacja: które ryzyka wymagają natychmiastowej uwagi

Na początku należy zająć się ryzykami o największym prawdopodobieństwie, które można zniwelować niskim nakładem finansowym: Ryzyko 1 (Phishing), Ryzyko 3 (dostęp VPN), Ryzyko 5 (BitLocker).

4. Plan wdrożenia – ogólny

- Priorytety: co robić najpierw (szybkie wygrane), co później (projekty strategiczne)

Szybkie wygrane: Należy w pełni wykorzystać narzędzia, które są aktualnie dostępne (w ramach Windows 11 oraz Microsoft 365), ale firma z nich nie korzysta. Uruchomienie BitLocker, wdrożenie uwierzytelniania dwuskładnikowego (MFA) dla dostępu do poczty e-mail oraz VPN, inwentaryzacja darmowym narzędziem (np. Snipe-IT).

Projekty strategiczne: Podjęcie czynności wymagających zaplanowania budżetu, zakupu licencji, czy chwilowych przerw technicznych w funkcjonowaniu przedsiębiorstwa. Konieczne jest skupienie się na wdrożeniu backupu w chmurze, zastosować segmentację sieci (VLAN), szkolenia pracowników z potencjalnych zagrożeń, zaimplementowanie bardziej zaawansowanego antywirusa oraz skonfigurowanie go pod specyfikę przedsiębiorstwa.

- Fazy wdrożenia: Faza 1 (0-3 mies.), Faza 2 (3-9 mies.), Faza 3 (9-18 mies.)

Faza 1 (0-3 mies.):

Miesiąc 1: Wdrożenie Snipe-IT oraz sporządzenie pełnej inwentaryzacji sprzętu w firmie. Włączenie szyfrowania BitLocker poprzez GPO.

Miesiąc 2: Rozpocząć informowanie pracowników o potencjalnych zagrożeniach oraz testowe wprowadzenie uwierzytelniania dwuskładnikowego w dziale IT oraz zarządzie.

Miesiąc 3: Wdrożenie uwierzytelniania dwuskładnikowego dla każdego z pracowników.

Faza 2 (3-9 mies.):

Miesiąc 4-5: Zakup oraz wdrożenie rozwiązania dla tworzenia kopii zapasowych w chmurze. Testowanie odtwarzania danych.

Miesiąc 6-7: Rozpoczęcie szkoleń pracowników online oraz przeprowadzanie symulacji phishingu.

Miesiąc 8-9: Wdrożenie segmentacji sieci (VLAN oddzielny na serwery, użytkowników oraz gości).

Faza 3 (9-18 mies.):

Miesiąc 10-12: Zakupienie oraz testowanie systemu EDR (Endpoint Detection and Response) do aktywnego monitorowania zagrożeń na laptopach.

Miesiąc 13-15: Przygotowanie oficjalnego planu reagowania na incydenty oraz ustalenie polityki haseł i dostępu.

Miesiąc 16-18: Wykonanie zewnętrznego skanowania podatności, sprawdzenie aktualnych zabezpieczeń firmy wraz z ewentualnym łataniem luk.

- Wstępny timeline z kamieniami milowymi

Kamień milowy 1: Wszystkie laptopy mają aktywny BitLocker oraz każdy z pracowników korzysta z uwierzytelniania dwuskładnikowego. Krytyczne ryzyka zostały obniżone.

Kamień milowy 2: Poprawiona infrastruktura sieciowa, przetestowany backup w chmurze.

Kamień milowy 3: Wdrożony EDR, który będzie czuwał nad urządzeniami, przeszkoleni pracownicy, opracowany plan reagowania na incydenty.

Część II– Implementacja i finalizacja

5. Szczegółowy plan zabezpieczeń

- Konkretnie środki techniczne dla każdego zidentyfikowanego ryzyka/luki

Ryzyko 1: Przejęcie konta e-mail spedytora poprzez zainfekowane pliki z fakturami i wyłudzenia przelewów fałszywymi fakturami.

Środki techniczne: Zaimplementowanie uwierzytelniania dwuskładnikowego, konfiguracja antywirusa przed złośliwym oprogramowaniem (automatyczne skanowanie i blokowanie podejrzanych e-maili).

Ryzyko 2: Zaszifrowanie kluczowych serwerów i laptopów przez złośliwe oprogramowanie, zatrzymujące pracę.

Środki techniczne: Wdrożenie systemu EDR w celu blokowania ransomware, segmentacja sieci na posiadanym firewallu w celu odseparowania użytkowników od serwerów.

Ryzyko 3: Dostęp do firmy nieproszonych osób przez VPN, które przejęły dane logowania pracowników z zewnętrznych stron.

Środki techniczne: Wdrożenie uwierzytelniania dwuskładnikowego za pomocą aplikacji mobilnej Microsoft Authenticator przy każdej próbie połączenia.

Ryzyko 4: Zagubienie, bądź kradzież laptopa, co oznacza dostęp do nie zaszyfrowanego dysku.

Środki techniczne: Aktywowanie szyfrowania, każdego laptopa za pomocą BitLocker, konfiguracja GPO.

Ryzyko 5: Awaria jedyne go dysku NAS z kopiami zapasowymi.

Środki techniczne: Wdrożenie systemu backupu 3-2-1 poprzez kopie zapasową w chmurze. Wykorzystanie w chmurze funkcji Immutability, która gwarantuje niezmiennosć kopii zapasowej.

- Wybór narzędzi i produktów (open source i komercyjnych) z uzasadnieniem

1. Snipe-IT - Open Source

Ma na celu inwentaryzację sprzętu i oprogramowania. Rozwiąże problem braku ewidencji, bez ponoszenia dodatkowych kosztów.

2. Microsoft Entra ID oraz Microsoft Authenticator - Komercyjne

Zostanie wykorzystane w ramach licencji Microsoft 365. Pozwoli na zarządzanie tożsamością, wymusi uwierzytelnianie dwuskładnikowe.

3. Microsoft BitLocker - Komercyjne

BitLocker jest wbudowany w Windows 11. Szyfruje całą powierzchnię dyskową, co w razie utraty urządzenia zabezpiecza dane firmy. Klucze są przechowywane w Active Directory.

4. Veeam Backup & Replication + chmura Wasabi - Komercyjne

Pozwala na tworzenie kopii zapasowych w systemie 3-2-1 z ochroną przed ransomware. Veeam odtwarza maszyny wirtualne. Chmura Wasabi jest budżetową opcją i nie pobiera opłat za dane wychodzące. Obsługuje opcje Immutability, co gwarantuje brak możliwości szyfrowania backupu.

5. Microsoft Defender for Endpoint - Komercyjne

System EDR będzie aktywnie blokował zagrożenia. Zapewnia wgląd działowi IT w laptopy użytkowników. Nie obciąża podzespołów urządzenia, ponieważ jest zintegrowane z systemem Windows 11.

6. KnowBe4 - Komercyjne

Platforma do szkoleń z Security oraz symulowania phishingu. Pozwala zaoszczędzić czas zespołowi IT z racji gotowych materiałów do szkoleń pracowników.

- Konfiguracje i punkty integracji

1. VPN (FortiGate) + Microsoft Entra ID (MFA)

Połączenie Fortinet FortiGate 60F do Microsoft Entra ID za pomocą protokołu SAML (Security Assertion Markup Language). Użytkownik chcąc połączyć się do sieci firmowej z domu, zostanie przekierowany do ekranu Microsoft, który wymusi od niego potwierdzenie tożsamości za pomocą aplikacji Microsoft Authenticator na telefonie.

2. Giełda Trans.eu + Microsoft Entra ID

Skonfigurowanie Single Sign-On (SSO) w panelu Microsoft 365 do zewnętrznych aplikacji SaaS. Spedytorzy będą logować się na giełdę transportową za pomocą konta firmowego, które wymusza MFA.

3. BitLocker + Active Directory (GPO)

Odpowiednia konfiguracja GPO (Group Policy Objects) w AD. Wymusi szyfrowanie dysków (AES-256) na wszystkich laptopach.

4. Veeam + Wasabi Cloud

Konfiguracja serwera Veeam z chmurą Wasabi za pomocą bezpiecznych kluczy API S3 (Amazon S3 Compatible API). Veeam tworzy kopie zapasowe systemu TMS i wysyła je szyfrowanym kanałem do chmury.

5. Defender EDR + M365 Defender Portal

Wdrożenie agentów EDR na każdym laptopie poprzez GPO. IT może monitorować urządzenia w jednym miejscu.

6. FortiGate 60F + Switch

Stworzenie wirtualnych sieci LAN (VLAN) na switchach. Podział na 3 strefy (VLAN 10 - Serwery, VLAN 20 - Spedytorzy, VLAN 30 - Goście). Z poziomu FortiGate będziemy zarządzać ruchem firmy.

- Diagramy architektury bezpieczeństwa (przed/po)

Diagram architektury bezpieczeństwa - przed

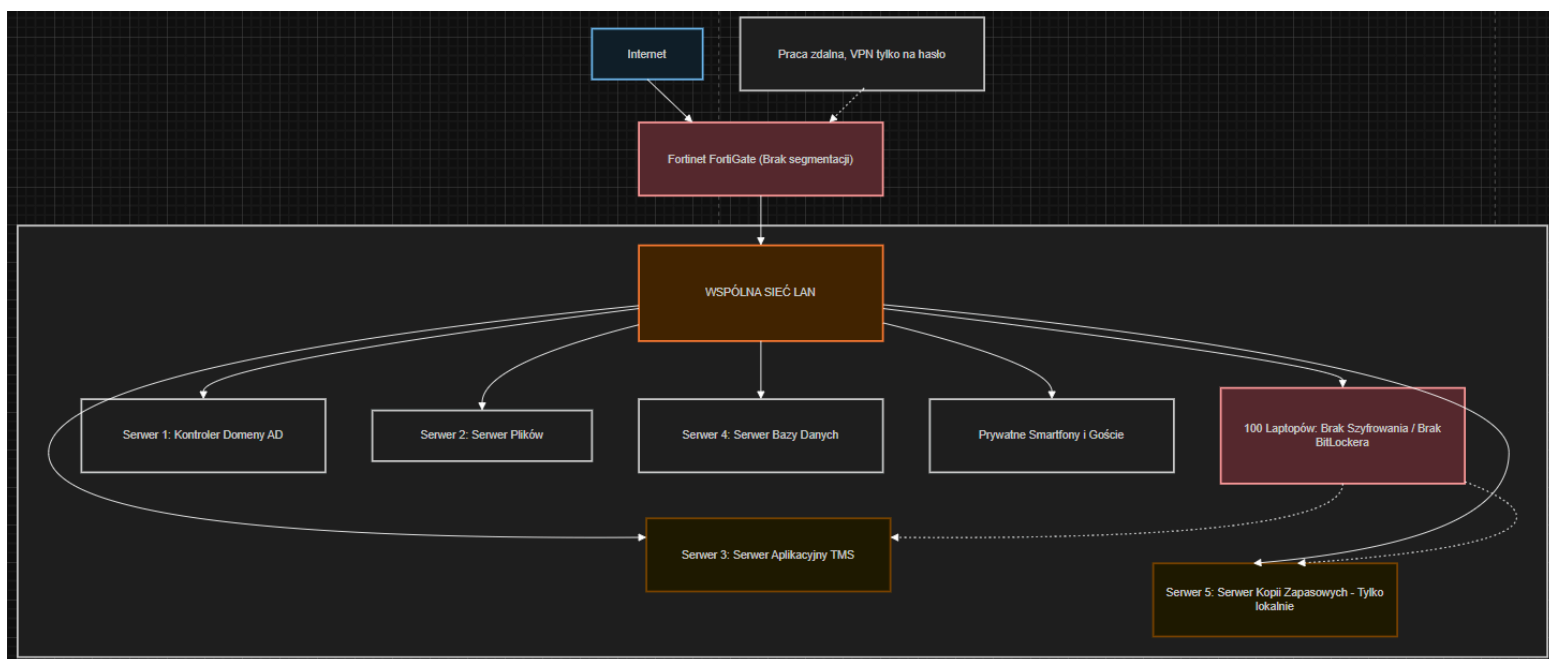
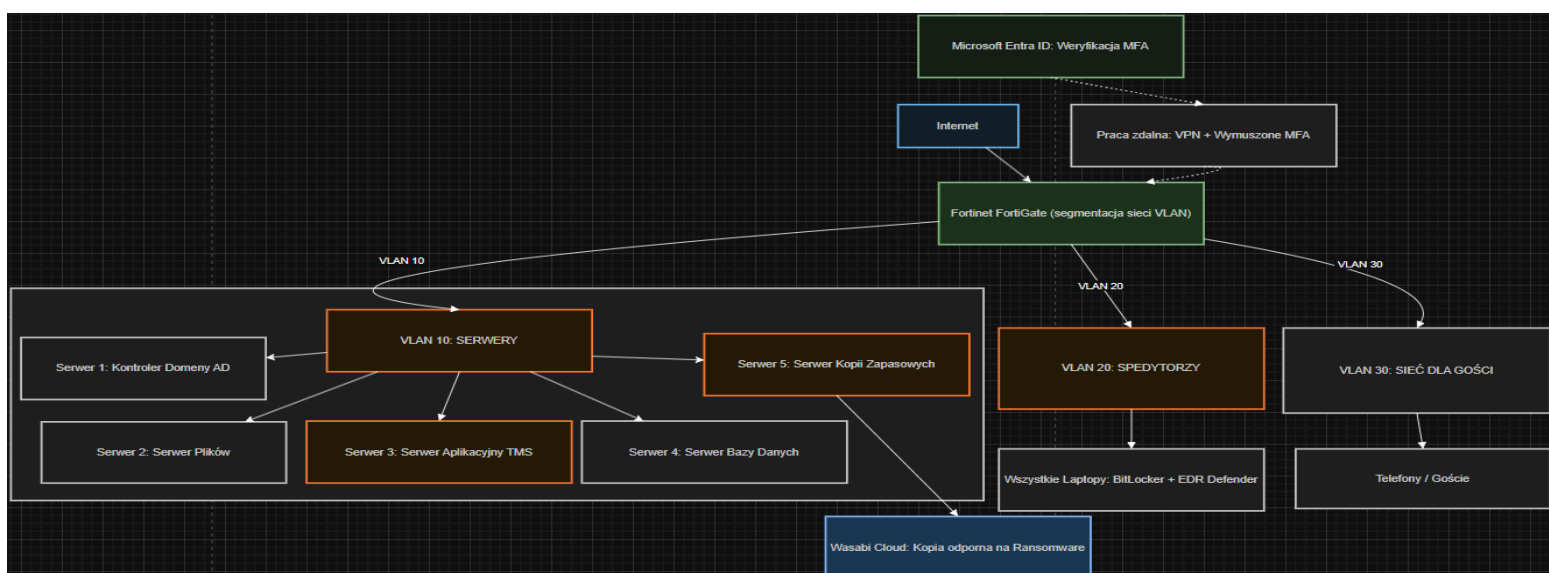


Diagram architektury bezpieczeństwa - po



6. Polityki i procedury

- Jakie polityki trzeba stworzyć/zaktualizować

1. Polityka kontroli dostępu:

- zasada najniższych uprawnień
- wymuszone uwierzytelnianie dwuskładnikowe
- wymagane złożone hasła

2. Polityka pracy zdalnej oraz telefonów:

- każde urządzenie służbowe musi mieć włączony BitLocker
- określenie jasnych zasad połączeń VPN
- zablokowanie używania urządzeń zewnętrznych
- wprowadzenie procedur w razie utraty urządzeń służbowych

3. Polityka kopii zapasowych i odzyskiwania danych:

- system 3-2-1: dane na serwerze, lokalny NAS oraz w chmurze Wasabi
- ustalenie zasad wykonywania backupu oraz jak długo będzie przechowywany
- testy sprawdzające sprawność backupu

4. Polityka reagowania na incydenty:

- zdefiniowanie potencjalnych zagrożeń
- instrukcja kogo pracownik ma poinformować w razie wykrycia potencjalnego ataku
- ustalenie kto będzie osobą decyzyjną w razie konieczności rozłączenia internetu w firmie lub wyłączeniu serwerów podczas ataku

5. Polityka czystego biurka i ekranu:

- zakaz zapisywania haseł na kartkach przyklejonych do monitora
- obowiązek blokowania monitora (Win + L), gdy pracownik odchodzi od stanowiska
- zakaz pozostawiania dokumentów na biurku, obowiązek przechowywania w zamykanych szafkach

- Role i odpowiedzialności (kto za co odpowiada)

Administrator IT: odpowiada za sprawność backupów, helpdesk, konfigurację firewalla i aktualizację systemu

Specjalista ds. Bezpieczeństwa: odpowiada za nadzorowanie logów, szkolenie pracowników, opracowywanie i aktualizowanie polityk, audyt zabezpieczeń firmy

Zarząd: zatwierdzanie polityk, budżetów, egzekwowanie konsekwencji za rażące niedbalstwo

Spedytorzy: obowiązek przestrzegania polityki, uczestniczyć w firmowych szkoleniach oraz zgłaszać incydenty zagrażające bezpieczeństwu firmy

- Program szkoleń dla pracowników (Świadomość bezpieczeństwa)

Człowiek zawsze jest najsłabszym ogniwem. Każdy ma chwile słabości, w które cyberprzestępca może trafić oraz wykorzystać. Konieczne jest wprowadzenie poniższego programu:

- każdy z pracowników musi przejść obowiązkowe szkolenie z podstaw bezpieczeństwa (uwierzytelnianie dwuskładnikowe, jak wykryć phishing, zgłaszanie incydentów)
- raz w miesiącu wysłać do pracowników symulację phishingu, raz w roku zorganizować quiz
- bieżące informowanie pracowników z aktualnych metod cyberprzestępców

- Plan zarządzania zmianą (jak wdrożyć zmiany bez paraliżowania biznesu)

Zmiany nie mogą zostać wprowadzone nagle. Konieczne jest opracowanie strategii:

- 1) Każdą zmianę najpierw testuje zespół IT oraz zarząd.
- 2) Przygotowanie instrukcji logowania do VPN oraz użytkowania uwierzytelniania dwuskładowego.
- 3) Wszelkie aktualizacje, bądź modernizacje sieci muszą odbywać się w nocy lub w weekend, żeby nie blokować pracy operacyjnej.

7. Budżet i uzasadnienie biznesowe

- Lista narzędzi i rozwiązań z przybliżonymi kategoriami cenowymi

Narzędzia i rozwiązania	Kategoria cenowa	Uzasadnienie
Snipe-IT	Open Source	Prowadzenie inwentaryzacji sprzętu
MFA (Entra ID)	W pakiecie Microsoft 365	Weryfikacja tożsamości, ochrona przed atakami
Veeam + Wasabi	10-20 tys. PLN/rok	Ochrona przed ransomware, koszt odtworzenia danych bez backupu jest znacznie wyższy
Defender for Endpoint	15-25 tys. PLN/rok	Ochrona przed złośliwym oprogramowaniem
KnowBe4	do 10k PLN	Przeszkoleni pracownicy minimalizują ryzyko ulegnięciu ataku poprzez phishing

- Zwrot z inwestycji (ROI) i uzasadnienie każdej większej inwestycji

Gdy nie wdrożymy EDR oraz segmentacji sieci ryzykujemy zainfekowanie ransomware, który zaszyfruje nam wszystkie dane. Koszt odblokowania może oscylować w okolicy 200 000 PLN za okup, który nie daje gwarancji odzyskania systemów.

Bez MFA i BitLocker ryzykujemy karą od UODO przy potencjalnej kradzieży laptopa oraz utratą reputacji u kontrahentów.

ROI: Inwestycja zwraca się przy zapobiegnięciu, chociaż jednemu atakowi.

- Porównanie: koszt zabezpieczeń vs potencjalne straty z incydentu

Koszt zabezpieczeń: około 5000 - 7000 PLN miesięcznie.

Potencjalne straty z incydentu: firma zarabia tylko i wyłącznie, gdy ma dostępne narzędzia pracy oraz systemy są sprawne. Każdy przestój oznacza znaczne straty finansowe. Podczas infekcji jest możliwość stracić nawet 200 000 PLN jednorazowo.

8. Metryki sukcesu

- Jak zmierzimy czy projekt się powiódł

Projekt będzie uznany za poprawnie zrealizowany, gdy ryzyko zostanie zredukowane. Wszystkie luki muszą zostać załatwane, zostanie wprowadzone MFA, szyfrowanie BitLocker, segmentacja sieci (VLAN), system backupu 3-2-1. Wprowadzenie zabezpieczeń bezpieczeństwa nie wpłynęło na przestoje w pracy operacyjnej. Firma może przedstawić kontrahentom udokumentowaną politykę bezpieczeństwa.

- Wskaźniki KPI i monitoring

Wdrożenie MFA - cel: 100% korzystania z dwuskładnikowego uwierzytelniania

Szyfrowanie BitLocker - cel: 100% zaszyfrowanych urządzeń

Backup - cel: 100% skuteczności

Świadomość pracowników - cel: 100% przeszkolenia

Odporność na phishing - cel: spadek poniżej 5% w skali roku

- Częstotliwość raportowania dla zarządu

Firma ma niski apetyt na ryzyko, więc raporty będą podzielone na miesięczne oraz kwartalne. Dodatkowy raport poza powyższymi będzie generowany w razie wystąpienia poważnego incydentu zagrażającemu bezpieczeństwu.

9. Mapa drogowa i harmonogram

- Szczegółowy harmonogram wdrożenia

Proces został rozplanowany, aby wykorzystać na początku dostępne zasoby w celu zminimalizowania ryzyka, a następnie stopniowo wdrażać zaawansowane procedury.

- Szybkie wygrane (0-3 mies.): najprostsze/najważniejsze działania

Miesiąc 1: Pełna inwentaryzacja w Snipe-IT oraz aktywacja szyfrowania BitLocker na wszystkich laptopach poprzez GPO.

Miesiąc 2: Przygotowanie instrukcji dla pracowników oraz wdrożenie MFA (Microsoft Authenticator) w dziale IT oraz Zarządzie.

Miesiąc 3: Obowiązkowe wdrożenie MFA dla wszystkich spedytorów (poczta e-mail, VPN, giełdy transportowe).

- Główne wdrożenie (3-9 mies.): główne projekty

Miesiąc 4–5: Zakup i wdrożenie systemu backupu Veeam z kopią w chmurze Wasabi (Immutability) oraz przeprowadzenie testów odzyskiwania danych.

Miesiąc 6–7: Rozpoczęcie szkoleń pracowników na platformie KnowBe4 oraz testowanie pracowników za pomocą symulacji phishingu.

Miesiąc 8–9: Skonfigurowanie segmentacji sieci (VLAN) na firewallu FortiGate w celu odizolowania serwerów od laptopów spedytatorów i stworzenia odseparowanej sieci dla gości.

- Budowanie dojrzałości (9-18 mies.): doskonalenie i optymalizacja

Miesiąc 10–12: Instalacja oraz konfiguracja agentów EDR (Microsoft Defender for Endpoint) na wszystkich laptopach.

Miesiąc 13–15: Opracowanie i przetestowanie zatwierdzonego Planu Reagowania na Incydenty (Incident Response Plan) oraz polityki czystego biurka i ekranu.

Miesiąc 16–18: Przeprowadzenie zewnętrznego skanowania podatności i audytu bezpieczeństwa w celu weryfikacji skuteczności wdrożonych zmian.

- Zależności i ścieżka krytyczna

Ścieżka krytyczna: Wdrożenie MFA jest priorytetem, ponieważ chroni dostęp do systemów giełdowych i poczty, które są kluczowe dla płynności finansowej.

Zależność techniczna: Uruchomienie EDR powinno nastąpić po wdrożeniu BitLockera i MFA, aby administratorzy mogli skupić się na analizie zaawansowanych zagrożeń, mając już zabezpieczone tożsamości i dane na dyskach.

Zależność operacyjna: Segmentacja sieci oraz aktualizacje muszą być wykonywane w nocy lub w weekendy, ponieważ wiążą się z chwilowym brakiem dostępu do serwera TMS.